Secure Development Policy (SDLC)

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review

Purpose

To ensure that all software developed or deployed by Stark Industries Inc. is secure by design, coded to prevent vulnerabilities, tested thoroughly, and maintained in accordance with secure development practices and industry standards. This policy is aligned with ISO/IEC 27001:2022 (A.8.25 – A.8.29).

Scope

Applies to all software developed, maintained, or deployed by Stark Industries Inc., including backend systems, APIs, SaaS applications, admin dashboards, CI/CD pipelines, and integration scripts.

Policy Objectives

- Integrate security into every stage of the software development lifecycle (SDLC)
- Prevent security flaws during coding, build, and deployment
- Comply with industry standards and customer security expectations
- Ensure quick remediation of vulnerabilities

Secure Development Requirements

1) Design Phase (A.8.25)

    - Threat modelling must be performed for all major releases or new systems
    - Security requirements must be documented along with functional specs
    - Reuse of secure libraries and components is encouraged

2) Development Phase

    - Developers must follow secure coding standards (e.g. OWASP Secure Coding Guidelines)
    - Static code analysis must be integrated into the CI/CD pipeline
    - Secrets and credentials must **never** be hardcoded in source code
    - All third-party libraries must be vetted for vulnerabilities

3) Testing and QA (A.8.29)

   - Conduct security testing before production releases:
     - Static Application Security Testing (SAST)
     - Dynamic Application Security Testing (DAST)
     - Manual code reviews for critical components
   - Use test data, never production data, in non-production environments

4) Deployment and Maintenance

   - All deployments must go through a peer-reviewed pull request (PR) process
   - Infrastructure-as-code (IaC) must be reviewed for misconfigurations
   - Post-deployment monitoring must be in place for all major releases

Secure Coding Training (A.6.3 & A.8.27)

- All developers must complete secure coding training **annually**
- New hires must complete training within 30 days of joining
- Training is tracked and reviewed by the Information Security Manager

Management of Open-Source Software (A.8.28)

- All third-party dependencies must be:
  - Managed using dependency management tools (e.g. npm, pip)
  - Checked regularly for CVEs or critical bugs
  - Updated or replaced if found vulnerable

DevOps and CI/CD Pipeline Controls

- Secrets must be stored using environment variables or secrets managers (e.g. AWS Secrets Manager)
- CI/CD pipelines must have:
  - Access control
  - Audit logging

    - Pre-deployment validation steps

Vulnerability Management

- Security vulnerabilities must be:
    - Tracked in an internal issue tracker
    - Assigned to developers and fixed based on severity
    - Verified through re-testing
- Critical vulnerabilities must be remediated within 5 business days

Roles and Responsibilities

Role	Responsibilities
Software Developers	Follow secure coding practices and participate in code reviews
Product Owners	Define security requirements and ensure they are delivered
Information Security Manager	Oversees policy implementation and training

Exceptions

- Exceptions must be:
    - Documented
    - Approved by the Information Security Manager
    - Mitigated with alternative controls where feasible

Policy Review

- This policy is reviewed **annually** or upon significant change to the environment or regulatory requirements.